This can leak the token to other servers. For example, if you redirect the user to an external login service. The fragment component is not sent to the server and is not included in Referer headers.

6. a, d
7. b, c, e

[34] This example is taken from “Paradigm Regained: Abstraction Mechanisms for Access Control”, see http://www.erights.org/talks/asian03/paradigm-revised.pdf

[35] There are proposals to make OAuth work better for these kinds of transactional one-off operations, such as https://oauth.xyz, but these still require the app to know what resource it wants to access before it begins the flow.

[36] The E language distributed protocol, and Cap’n Proto, instead use per-connection tables of capabilities so that a capability can only be used over the communication channel that it was originally transmitted. This violates the principle of statelessness in REST and in practice relies on the cryptographic integrity of the communication channels anyway, so we’ll ignore that solution here in favor of cryptographic capabilities.

[37] You can get the project from https://github.com/NeilMadden/apisecurityinaction if you’ve not worked through chapter 8. Checkout branch chapter09.

[38] In this chapter you’ll return links as URIs within normal JSON fields. There are standard ways of representing links in JSON, such as JSON-LD (https://json-ld.org), but I won’t cover those in this book.

[39] If you are a functional programming enthusiast then this can be elegantly written as a left-fold or reduce operation.